Hospital Information Management System (HIMS)

Submitted to:

Sharine A. Gutierrez, MSIT
Assistant Professor II

Submitted by:

Adecer, Mariah Desiree A.
Bombales, Rena S.
Quibral, Althea Raein V.
Villaflores, Denzel B.

Contents

I. Application/System Identification 3

1. Information System Name/Title....3
2. Information Contact(s)....3
3. Information System Operational Status....3
4. Applicable Laws or Regulations Affecting the System....3

II. Security Roles and Responsibilities 4

III. Staff SDLC Security Task Orientation 5

IV. System Criticality Level 6

V. Information Classification 7

VI. Security Profile Objectives 7

VII. System Profile 8

VIII. System Decomposition 8

IX. Vulnerability and Threat Assessment 9

X. Risk Assessment 9

XI. Security Controls Selection and Documentation 10

XII. Test Data Creation 10

XIII. Security Control Testing 10

XIV. Accreditation (Executive Level Sign-off) 10

XV. Change Management and Control 11

XVI. Security Compliance Measurement 11

XVII. System Disposal 11

Appendix A: Available Resources 11

Appendix B: Interview Documentation 12

I. Application/System Identification

1. Information System Name/Title:

HOSPITAL INFORMATION MANAGEMENT SYSTEM

The Hospital Information Management System (HIMS) is an integrated hospital platform composed of multiple subsystems including Electronic Medical Records (EMR), billing, claims processing, inventory management, and financial management systems. It is designed to support hospital operations through centralized digital processing of clinical and administrative data.

2. Information Contact(s)
Information owner & name of person(s) responsible for/knowledgeable about the application/system:

- Name: Glenn Alemania
- Title: IMIS Office Head / CMT 8

3. Information System Operational Status

The HIMS is currently fully operational and actively used in the hospital's daily processes. It is integrated across multiple departments, supporting clinical, financial, and administrative workflows.

4. Applicable Laws or Regulations Affecting the System

Although the interviewee did not mention any formal legal frameworks, hospital information systems in the Philippines generally follow national laws and regulatory bodies that ensure data protection and healthcare compliance.

The system is expected to comply with:

- **Republic Act No. 10173 – Data Privacy Act of 2012**, which mandates protection of personal and sensitive personal information, including patient health records.
- **National Privacy Commission (NPC) Guidelines**, which enforce data privacy compliance for organizations handling personal data.
- **Department of Health (DOH) Standards for Hospital Systems**, which regulate healthcare service delivery systems and accreditation requirements.
- **PhilHealth Accreditation Requirements**, particularly for claims processing and billing integration within hospital systems.

Additionally, the system is accredited by DOH and PhilHealth and uses compliance validation mechanisms provided by these agencies to ensure operational standards are met.

II. Security Roles and Responsibilities

Security Roles and Assignments		
Security Role	**Name and Contact Information**	**Security Responsibilities**
Authorizing Official (AO)	Name: Hon. Ricarte "Dong" R. Padilla Title: Governor	Senior official authorized to formally accept responsibility for operating the system. Grants the final "Executive Level Sign-off" or Accreditation to Operate (ATO).
Chief Information Officer (CIO)	Name: Glenn Alemania Title: IMIS Office Head/CMT II	In charge of developing, maintaining and controlling the agencies information technology planning, budgeting, and performance.
Configuration Management (CM) Manager	Name: John Kenneth Rivera Title: Technical Support Lead	Holds the change control process and makes sure that all security documentation is changing when the system is changed.
Information System Security Officer	Name: Angelo Lance Larazang Title: Technical Support	Manages day-to-day security operations and serves as the principal advisor on the system's security posture.
Privacy Officer	Name: Harold Pocholo S. Mejia, MD Title: MS II / Acting Chief of Hospital II	Oversees the protection of sensitive patient health information and ensures the system follows data privacy laws.
Program Manager / Official (Information Owner)	Name: Harold Pocholo S. Mejia, MD Title: MS II / Acting Chief of Hospital II	Establishes requirements for data confidentiality, integrity, and availability for the hospital.
QA / Test Director	Name: Janice Bolohab Title: Administrative Lead	Directs the creation of test data and oversees security and regression testing for the system.
Senior Agency Information Security Officer (SAISO)	Name: Glenn Alemania Title: IMIS Office Head/CMT II	Responsible for the agency-wide information security program and reporting to the Authorizing Official.
Software Developer	Name: Franco Duane Daniel Title: Lead Developer/Programmer	Implements the security controls within the application code and supports system decomposition.

Security Roles and Assignments		
Security Role	**Name and Contact Information**	**Security Responsibilities**
System Architect	Name: Angelica Discaya Title: Computerization Supervisor	Documents the system profile, including physical topology, logical tiers, and data flow entry/exit points.
System Owner	Name: Francis Christian Rafer Title: IMIS Operations Deputy	Responsible for the overall maintenance and operational status of the IMIS environment.
Other Participants	Name: Technical Support Team Title: Technical Support Team	Assist in vulnerability assessments, hardware maintenance, and daily troubleshooting of system components.
Note: The addresses, email addresses and phone numbers from the personnel listed above are not included for privacy reasons.		

III. Staff SDLC Security Task Orientation

The listed personnel are responsible for assuring that orientation is provided to all parties responsible for performing security awareness activities as part of the application system's SDLC process.

Security Role	Name and Contact Information
Responsible Person	Name: Glenn Alemania Title: IMIS Office Head/CMT II Name: Harold Pocholo S. Mejia, MD Title: MS II / Acting Chief of Hospital II

To familiarize all the staff with the security responsibilities and the techniques used in safeguarding the Integrated Management Information System (IMIS), the following orientation program has been implemented:

First phase of System Development Life Cycle (SDLC) orientation will be given to the System & Technical Support Team and Development Team focusing on the Security Awareness briefing. Role-Specific Security Training is implemented to make sure all the personnel that use computers working off a dedicated ER, Ward, or Admitting Computerization system are trained on the data sensitivities and access authorizations connected to those specific modules.

Furthermore, Vulnerability & Threat Orientation where ISSO's hold repeated sessions during the meeting with personnel, to teach how to recognize types of threat sources, attack method, and internal weaknesses. The Review of Policy and Compliance is where the employees are trained on the Applicable Laws and Regulations (e. g. data privacy laws) that define the standards for the confidentiality and integrity of hospital information.

Testing & Data Protection Procedures which includes the advice from the QA/Test Director on how to generate test data and what necessary procedures to follow to ensure the confidentiality of production information in the event it is used in testing. Lastly, Change Management Orientation has been conducted where the personnel are instructed on the formal process for change management and control to make sure all changes to the system are recorded and security activities are taken into account before application.

IV. System Criticality Level

Table II-B-2: System Criticality Profile

System / Application Name	Criticality Level (MC/MI/MS)	Description
Hospital Information Management System (HIMS)	Mission Critical	The system is essential for hospital operations, including patient records, billing, and claims processing. While healthcare services can continue manually during downtime, overall hospital efficiency and processing of provided services will be significantly affected.

Determining the HIMS to be Mission Critical (MC) is properly justified since this automated resource is solely responsible for the mission critical processes of the provincial hospital business. Applying the NIST 800-64 criteria for MC classification, any system whose failure prevents an organization from fulfilling its primary mission is MC. In this case, the HIMS consolidates functions for EMR, ER, and admitting processes into one automated application. Even without the HIMS available, clinical staff would, of course, be able to proceed manually, yet the inability to quickly generate vital information will bottleneck emergency response and clinical analysis.

In addition, HIMS is a must for hospital administrative and financial integrity and its ineffectiveness. To be specific, its modules of billing and claims, procurement for inventory, and all testing systems would effectively halt the hospital's ability to check insurance or discharge infected patients or keep inventories of medications. If that system fails, it shall not be able to provide hospitals with any data. Considering that the IMIS Office has appointed the responsible to run IMIS in HIMS and appointed the ISSO to protect the data availability by providing data backup, data recovery and set up a plan and process to keep the data available for the hospital, it is evidenced that HIMS is the Mission Critical. Since unavailable immediately will degrade the quality

of patient care and daily operation of the facility severely, Mission Critical shall be used.

V. Information Classification

The Hospital Information Management System (HIMS) processes highly sensitive information that includes:

- Patient Medical Records
- Billing and Financial Records
- Laboratory and Diagnostic Data
- Hospital Inventory and Supply Data

For the classification level these are highly confidential. According to the Data Privacy Act of 2012, all patient-related data is classified as sensitive personal information requiring strict access control and protection measures.

VI. Security Profile Objectives

The Hospital Information Management System (HIMS) aims to maintain the confidentiality, integrity and availability of hospital information and services throughout all the phases of the System Development Life Cycle (SDLC).

The following are the security objectives of the system:

- **Confidentiality:** Ensure that all sensitive patient information and hospital records are only accessible to authorize users through role-based access control and authentication mechanisms.
- **Integrity**: Protect hospital data from unauthorized modifications, deletions, or corruptions by implementing encryption, audit logs,and regular backups.
- **Availability**: Ensure continuous access to hospital services and information systems through reliable infrastructure, backup systems, and data recovery procedure.
- **Compliance**: Ensure that the system adheres to laws, regulations, policies, and healthcare standards such as the Data Privacy Act of 2012, NPC guidelines, DOH standards, and PhilHealth requirements.

These objectives must be reviewed during each SDLC phase to ensure that security measures remain effective against emerging threats and vulnerabilities.

VII. System Profile

The Integrated Management Information System (IMIS) serves as the central data center and enterprise platform of the Camarines Norte Provincial Hospital that integrates clinical subsystems including EMR and administrative subsystems like Billing and Financials. The physical IMIS is still centered on a Star-Bus Topology at IMIS Office which maintains local servers that are endpoints at the ER, Wards, and Admitting offices. The logical structure of the Integrated Management Information System (IMIS) is broken down into three functional layers making the system modular and secure. The Presentation Tier where the system employs modernized web-based frameworks to offer the staff a visually immersive, high, usable and secure interface for visualization of high fidelity data across the clinical and administrative domains. The Application Tier which runs using an industry standard server-side scripting code and runs the core of the system such as hospital business logic and delivery system, and secure production of the automated performance reports. Lastly, Data Tier which is a central hardened database management system for storing and retrieving key medical, financial and administrative records securely with integrity.

The security of the system altogether depends on defining Trust Boundaries, the point at which confidential patient/procurement numbers flow between the hospital's corporate network and the user-interfaces at the hospital. Data entry point will occur with manual entry of clinical data by doctors, nurses and admin staff in the ER and Ward units. System exit points will be the self-extracting reports that will be handed to hospital admin for performance benchmarking and automatic files sent through the network for claims processing. Strong Role-Based Access Control (RBAC) will be employed so that actors ranging from Authorizing Official to hospital administration and hospital front-line doctors will only see authorized clinical and financial data. This decomposition will also ensure that the privileged code, namely controlling the DBMS and workflow is firewalled off from the hospital's core user interfaces.

VIII. System Decomposition

The Hospital Information Management System (HIMS) is composed of interconnected modules including Electronic Medical Records (EMR), patient registration, billing and claims processing, inventory management, and financial management. Each subsystem performs specific functions while sharing data through a centralized database system.

The system contains trust boundaries between hospital staff, users, administrators, and external entities such as PhilHealth and DOH agencies. Information entry points include computers located within where authorized

personnel input patient data and operational data. Exit points include a generated report, billing statements, and electronic claim submission.

The data flows through secured application servers and databases protected by role-based access control (RBAC). The privilege functions such as database administration, system configuration, and security management are restricted only to authorize technical personnel to prevent unauthorized modifications and ensure system security.

IX. Vulnerability and Threat Assessment

Vulnerability and threat assessment are regularly conducted throughout the SDLC to identify and address security weaknesses within the Hospital Information Management System (HIMS). Potential threats include unauthorized, malware, phishing attacks, data breaches, hardware failures, and network disruptions.

To prevent these risks, the hospital implements security measures such as role-based access control, antivirus protection, firewalls, regular system monitoring, password management, and data backup procedures. Periodic vulnerability scanning and security reviews are also performed by the Technical Support Team and Information Security Officer (ISSO).

X. Risk Assessment

The primary risks in the HIMS are mainly related to **internal user behavior**, such as unattended logged-in sessions and improper handling of accounts, which may lead to unauthorized access to patient and hospital data. Based on the interview, user negligence is considered the most common vulnerability in the system.

Other risks include potential data leakage and exposure of sensitive medical and financial information. Although the system is secured through an internal server environment, role-based access control (RBAC), and password-protected accounts, human error remains the main security concern.

To mitigate these risks, the hospital implements security controls such as access restrictions based on user roles, regular system backups, secured server room access, and periodic system maintenance in coordination with a third-party provider. Staff are also regularly oriented through monthly IMIS meetings to reinforce security practices.

Risk assessment is conducted throughout the SDLC process, starting informally during early stages and becoming more structured as the system progresses toward full implementation.

XI. Security Controls Selection and Documentation

Implemented security controls include:

- Role-Based Access Control (RBAC)
- Password-protected user authentication
- Physical security of server room (guarded access)
- Administrative policy enforcement via IMIS Office
- Regular policy updates through monthly security meetings

XII. Test Data Creation

Test data is created and managed internally by the IMIS Office and system provider.

- Non-sensitive test datasets are used for system testing.
- Production data is not typically used directly for testing unless necessary, and is handled with strict confidentiality controls.
- Testing includes validation of system updates, security patches, and module functionality.

XIII. Security Control Testing

Security testing is performed periodically in coordination with the third-party system provider.

Testing Environment: Controlled hospital server environment.
Testing Frequency: Based on the interview they conduct security testing approximately three times per year.
Focus: Access control, system integrity, and update validation.
Separation of Duties: IMIS manages internal oversight while the provider handles system-level testing and updates.

XIV. Accreditation (Executive Level Sign-off)

The system is accredited by PhilHealth and the Department of Health (DOH). Authorization is required before implementation of hospital systems, this ensures the compliance with healthcare and billing standards.

XV. Change Management and Control

The Hospital Information Management System follows a documented change management system process. All relevant SDLC security activities such as risk assessment, vulnerability testing and security validation are performed before changes are applied to the live system.

Controls within the change management process include the authorization procedures and security reviews. These controls ensure that all affected security controls and policies are properly updated and maintained whenever changes are made to the system.

XVI. Security Compliance Measurement

The HIMS compliance is ensured through:

- Adherence to DOH and PhilHealth accreditation standards
- Role-based access control monitoring
- Internal policy enforcement via IMIS Office
- Regular system reviews and maintenance activities

Compliance validation is supported by system certification mechanisms referenced by the interviewee as accreditation credentials issued by regulatory agencies.

XVII. System Disposal

When it comes to Data Disposal, HIMS follow strict audit and retention principles: Data is not permanently deleted without traceability, redundant or duplicate entries may be marked for removal, all deletion activities are logged in the system.

In Data Backup and Recovery, the system is implemented with daily backup feature. Backups are stored in a separate secure storage drive, so that in case of system failure or emergency data recovery is available.

Appendix A: Available Resources

- Republic Act No. 10173 – Data Privacy Act of 2012 https://privacy.gov.ph/data-privacy-act/
- National Privacy Commission (NPC) https://privacy.gov.ph/
- Department of Health (DOH), Philippines https://doh.gov.ph/
- PhilHealth Official Website https://www.philhealth.gov.ph/
- NIST SP 800-64 Rev. 2 – Security Considerations in SDLC https://csrc.nist.gov/pubs/sp/800/64/r2/final

Appendix B: Interview Documentation



(Figure 1. Interview conducted with IMIS Office Head regarding HIMS system)